



Information Security Risk Management Methodology — Aetheris Therapeutics S.p.A.

Framework di Valutazione e Gestione del Rischio ISO/IEC 27005:2022

Standard di Riferimento: ISO/IEC 27005:2022 & ISO/IEC 27001:2022 (Clausola 6.1)

Organizzazione: Aetheris Therapeutics S.p.A.

Rif. Documento: RSK-MTH-2026-01

Versione: 1.0

Stato: Approvato

Classificazione: Riservato / Per Uso d'Audit

Data di Efficacia: Agosto 2026

1. Obiettivo e Ambito di Applicazione

La presente **Metodologia di Gestione del Rischio** stabilisce le regole, i criteri e la scala di misurazione adottati da **Aetheris Therapeutics S.p.A.** per identificare, analizzare, valutare e trattare i rischi relativi alla sicurezza delle informazioni, in piena conformità allo standard **ISO/IEC 27005:2022**.

La metodologia si applica a tutti gli asset informativi, infrastrutture cloud/on-premise, processi R&D, dati clinici PII e risorse umane rientranti nello scope del SGSI.

2. Il Processo di Risk Assessment (ISO 27005)

Il processo si articola nelle seguenti fasi sequenziali:

- Asset Identification & Valuation:** Censimento degli asset e classificazione in base alla triade RID (Riservatezza, Integrità, Disponibilità).
- Threat & Vulnerability Identification:** Identificazione delle minacce esterne/interne e delle vulnerabilità associate.
- Inherent Risk Evaluation:** Calcolo del Rischio Inerente prima dell'applicazione dei controlli ($R_{inerente} = P \times I$).
- Risk Treatment & Control Mapping:** Selezione dei controlli di mitigazione ISO 27001 Annex A.
- Residual Risk Evaluation:** Calcolo del Rischio Residuale stimato a seguito della remediation ($R_{residuale}$).

3. Criteri e Scale di Valutazione (Matrice 5x5)

3.1 Scala della Probabilità (Likelihood - P)

Livello	Valore	Definizione Operativa	Frequenza Stimata
Molto Bassa	1	Minaccia altamente improbabile; richiede condizioni eccezionali	< 1 volta ogni 5 anni
Bassa	2	Evento raro ma possibile in condizioni particolari	1 volta ogni 2-5 anni
Media	3	Evento moderato; si è già verificato nel settore Pharma/Biotech	1 volta all'anno
Alta	4	Evento probabile; vulnerabilità note e minacce attive	Più volte all'anno
Molto Alta	5	Evento quasi certo; attacco o guasto imminente/frequente	Continuo / Mensile

3.2 Scala dell'Impatto (Impact - I)

Livello	Valore	Danno Finanziario / Operativo	Danno Reputazionale / Legal (GDPR)
Insignificante	1	Impatto economico irrilevante (< 10k €); nessun blocco operativo	Nessuna sanzione; nessun impatto mediatico
Minore	2	Disservizio locale risolvibile in poche ore (< 50k €)	Lieve insoddisfazione di terzi; reclamo minore
Moderato	3	Blocco parziale della R&D o di sistemi non critici (< 200k €)	Segnalazione al Garante GDPR senza sanzioni gravi
Maggiore	4	Interruzione critica dei servizi IT; perdita dati clinici (< 1M €)	Sanzione Garante GDPR; danno d'immagine nazionale
Catastrofico	5	Fuga di brevetti/proprietà intellettuale; blocco totale (> 1M €)	Revoca licenze, azioni penali, collasso aziendale

4. Matrice del Rischio e Criteri di Accettabilità

Il livello di rischio finale è calcolato come prodotto cartesiano:

Livello di Rischio = Probabilità (P) × Impatto (I)

Probabilità \ Impatto	Insignificante (1)	Minore (2)	Moderato (3)	Maggiore (4)	Catastrofico (5)
Molto Alta (5)	5 (Medio)	10 (Alto)	15 (Alto)	20 (Critico)	25 (Critico)
Alta (4)	4 (Basso)	8 (Medio)	12 (Alto)	16 (Alto)	20 (Critico)
Media (3)	3 (Basso)	6 (Medio)	9 (Medio)	12 (Alto)	15 (Alto)
Bassa (2)	2 (Basso)	4 (Basso)	6 (Medio)	8 (Medio)	10 (Alto)
Molto Basso (1)	1 (Basso)	2 (Basso)	3 (Basso)	4 (Basso)	5 (Medio)

4.1 Soglie di Accettazione del Rischio (Risk Appetite Thresholds)

- **Rischio Basso (1 – 4): ACCETTABILE** — Nessuna azione immediata richiesta; monitoraggio periodico.
- **Rischio Medio (5 – 9): TOLERABILE** — Richiede controlli di mitigazione nel medio periodo (entro 6 mesi).
- **Rischio Alto (10 – 16): INACCETTABILE** — Richiede intervento prioritario e piano di remediation (entro 90 giorni).
- **Rischio Critico (20 – 25): EXTREME RISK** — Richiede escalation immediata al Board/CEO e remediation urgente (30–45 giorni).

5. Strategie di Trattamento del Rischio (Clausola 6.1.3)

Per ogni rischio identificato nel *Risk Register*, Aetheris Therapeutics adotta una delle seguenti 4 opzioni:

1. **Mitigazione (Mitigate):** Applicazione di controlli tecnici/organizzativi ISO 27001 Annex A per ridurre P o I.
2. **Evitamento (Avoid):** Modifica del processo o eliminazione dell'asset per annullare la minaccia.
3. **Trasferimento (Transfer):** Trasferimento dell'impatto finanziario a terzi (es. Polizza Cyber Insurance o SLA con MSSP).
4. **Accettazione (Accept):** Formalizzazione dell'accettazione del rischio residuale da parte della Direzione (solo per rischio Basso/Medio).

6. Controllo Documentale e Approvazione (ISO 27001:2022 Clausola 7.5)

Ruolo	Nome e Cognome	Stato	Data
Redatto da (Lead Auditor)	Emanuele Tarchi	Completato	Agosto 2026
Revisionato da (IT Director)	IT Director ad interim	Revisionato	Agosto 2026
Approvato da (Alta Direzione)	Chief Executive Officer (CEO)	Approvato	Agosto 2026